Corso di Cybersecurity – Epicode

Report dell'Esercitazione

Vulnerability Assessment con Nessus su Metasploitable2

Scansione non autenticata, lettura dei risultati e analisi dei falsi positivi

A cura di:

Nicola Madonna

Epicode

19 ottobre 2026

Indice

1 Riassunto 2
2 Obiettivi 2
3 Configurazione del Laboratorio 3
3.1 Ambiente 3
3.2 Impostazioni della scansione 3
4 Analisi dei Dati Raccolti 5
4.1 Panoramica dei risultati 5
4.2 Vulnerabilità con evidenza diretta 5
4.3 Altre vulnerabilità rilevate 6
4.4 Probabili falsi positivi 8
4.5 Confronto con la scansione Nmap 11
4.6 Contromisure 12
5 Conclusioni 13

1 Riassunto

In questo laboratorio è stata eseguita con Nessus Essentials, installato su Kali Linux, una scansione di vulnerabilità contro Metasploitable2, la stessa macchina volutamente vulnerabile già analizzata con Nmap. La scansione, di tipo *Basic Network Scan* e senza credenziali, è durata 15 minuti e ha prodotto 64 rilevazioni critiche, 8 alte, 24 medie, 9 basse e 140 informative.

Tra i risultati ce ne sono due con un'evidenza diretta: una shell senza autenticazione sulla porta 1524, sulla quale Nessus è riuscito a eseguire il comando `id` ottenendo i privilegi di `root`, e un sistema operativo, Ubuntu 8.04, fuori supporto dal 2013. Seguono servizi in chiaro (Telnet, rlogin), condivisioni NFS leggibili da chiunque, versioni vulnerabili di Samba e BIND e numerose debolezze nella configurazione SSL/TLS.

La maggior parte delle rilevazioni critiche, almeno 50 su 64, riguarda però la vulnerabilità Log4Shell della libreria Java Log4j, segnalata su servizi che non usano Java, come DNS, FTP e Telnet. L'analisi dell'output dei plugin mostra che si tratta con ogni probabilità di falsi positivi, come altre due segnalazioni relative a software assente dalla macchina. Il report descrive quindi sia le vulnerabilità reali sia il lavoro di verifica necessario prima di fidarsi del numero di vulnerabilità critiche indicato dallo scanner.

2 Obiettivi

- Configurare ed eseguire una scansione di vulnerabilità non autenticata con Nessus Essentials contro Metasploitable2.
- Leggere i risultati per livello di gravità e individuare le vulnerabilità supportate da un'evidenza concreta.
- Riconoscere i risultati poco attendibili e motivare perché vanno considerati probabili falsi positivi.
- Confrontare quanto emerso con la scansione Nmap della stessa macchina e proporre le contromisure principali.

3 Configurazione del Laboratorio

3.1 Ambiente

Il laboratorio è composto da due macchine virtuali in VirtualBox collegate alla stessa rete interna. Kali Linux ospita lo scanner Nessus, Metasploitable2 è il bersaglio (Tabella 1).

Tabella 1: Macchine del laboratorio.

Macchina	**Ruolo**	**Indirizzo IP**	**Software**
Kali	scansione	192.168.200.100/24	Nessus Essentials (scanner locale)
Metasploitable2	bersaglio	192.168.200.102/24	Ubuntu 8.04, kernel Linux 2.6

Nessus è stato installato su Kali dal pacchetto `.deb` ufficiale, avviato con il servizio `nessusd` e utilizzato dall'interfaccia web all'indirizzo `https://localhost:8834`, dopo la registrazione della licenza gratuita Essentials.

3.2 Impostazioni della scansione

È stata creata una nuova scansione con il modello *Basic Network Scan*, chiamata *Scansione Metasploitable2*, con un solo bersaglio: 192.168.200.102 (Fig. 1).

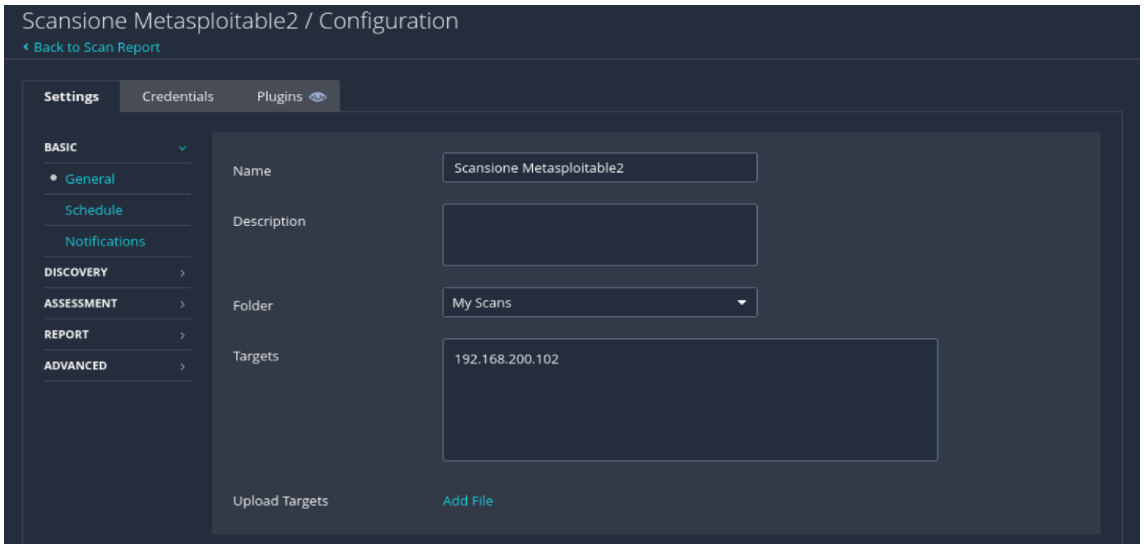
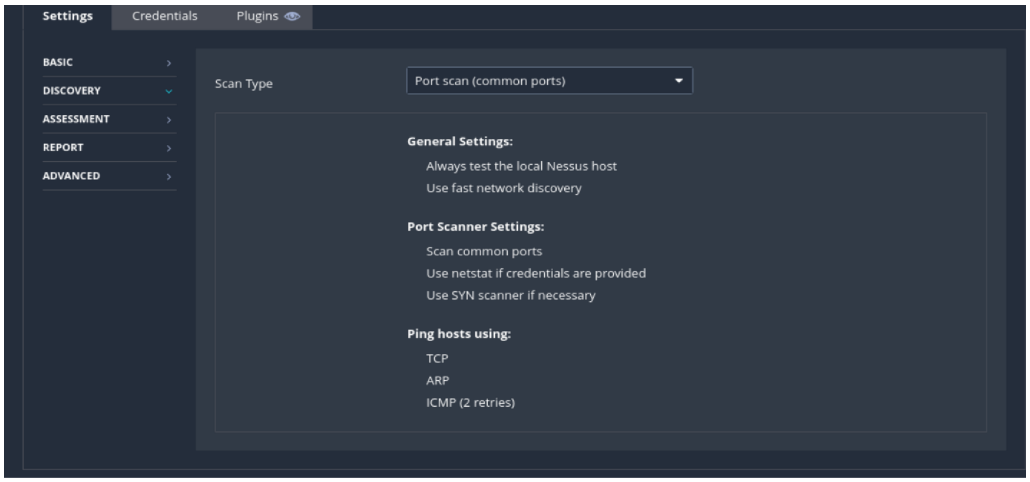


Figura 1: Impostazioni generali della scansione: nome e indirizzo del bersaglio.

Le altre opzioni sono rimaste ai valori predefiniti del modello (Fig. 2):

- **Discovery:** scansione delle porte più comuni, non di tutte le 65.535, con ricerca dell'host tramite TCP, ARP e ICMP;
- **Assessment:** impostazione *Default*, che evita i controlli più soggetti a falsi allarmi e disattiva la scansione delle applicazioni web;

- **Credentials:** nessuna credenziale inserita. La scansione vede quindi la macchina dall'esterno, come un attaccante sulla stessa rete, senza accedere al sistema per controllare i pacchetti installati.



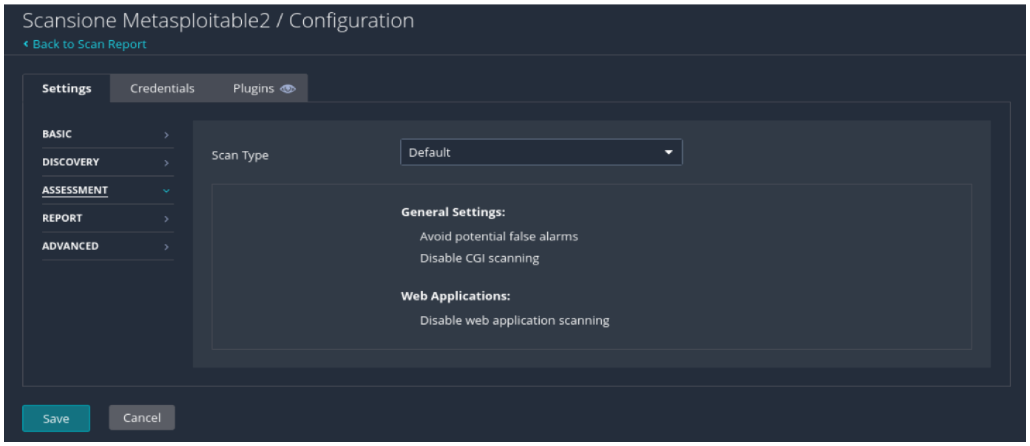


Figura 2: Impostazioni predefinite delle sezioni Discovery e Assessment.

4 Analisi dei Dati Raccolti

4.1 Panoramica dei risultati

La scansione è terminata in 15 minuti e ha trovato un solo host, 192.168.200.102 (Fig. 3). Le rilevazioni sono 64 critiche, 8 alte, 24 medie, 9 basse e 140 informative. Nella scheda *Vulnerabilities* sono raccolte in 80 voci raggruppate per famiglia, che diventano 134 disattivando il raggruppamento: una stessa vulnerabilità può infatti comparire più volte, una per ogni porta su cui viene rilevata.

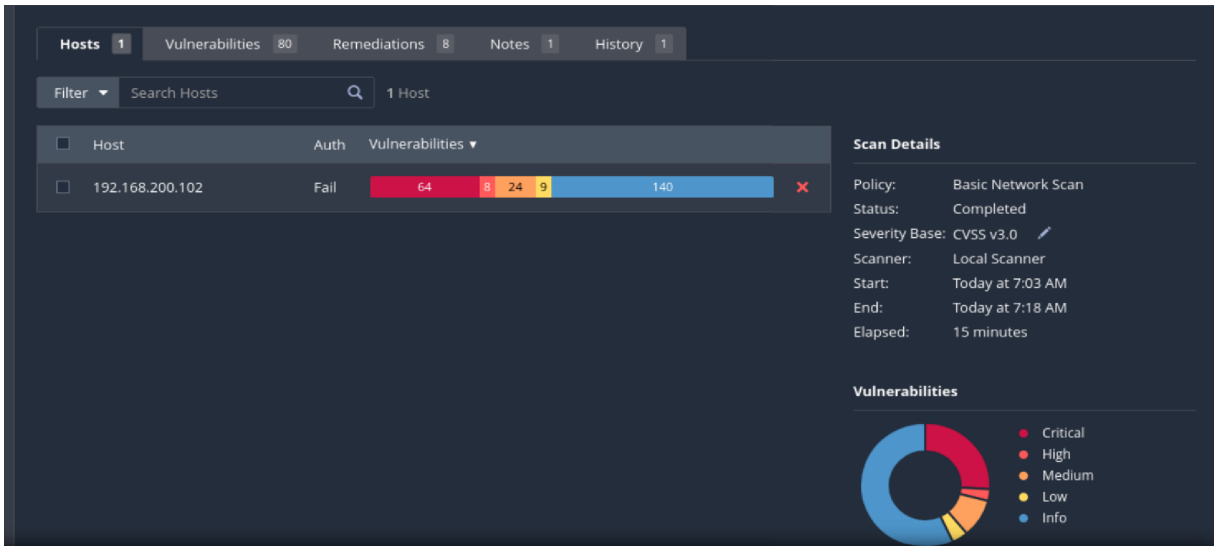


Figura 3: Riepilogo della scansione: un host, rilevazioni divise per gravità e durata di 15 minuti.

La colonna *Auth* riporta *Fail*: è il comportamento atteso, perché non sono state fornite credenziali. Nei dettagli dell'host Nessus identifica il sistema come *Linux Kernel 2.6 on Ubuntu 8.04 (hardy)*, coerente con quanto stimato da Nmap.

4.2 Vulnerabilità con evidenza diretta

Due risultati critici sono supportati da prove che non lasciano dubbi.

Bind Shell Backdoor Detection (plugin 51988, CVSS 9.8). Sulla porta 1524 è in ascolto una shell che non chiede alcuna autenticazione. Nessus si è collegato, ha inviato il comando `id` e ha ricevuto `uid=0(root) gid=0(root)`: chiunque raggiunga la porta ottiene il pieno controllo della macchina (Fig. 4). È lo stesso servizio che Nmap aveva identificato come *Metasploitable root shell*. Nessus indica come soluzione di verificare se l'host è stato compromesso e, se necessario, reinstallare il sistema.

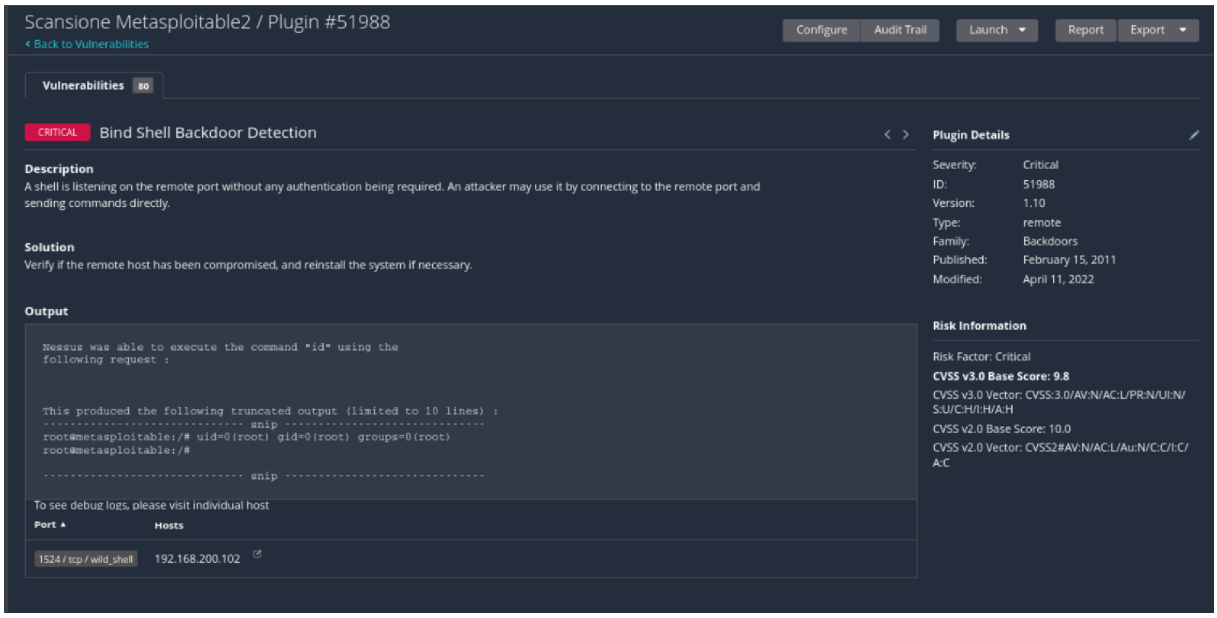


Figura 4: Bind Shell Backdoor Detection: il comando `id` eseguito sulla porta 1524 restituisce l'utente root.

Canonical Ubuntu Linux SEoL (8.04.x) (plugin 201352, CVSS 10.0). Il sistema operativo è Ubuntu 8.04, il cui supporto di sicurezza è terminato il 9 maggio 2013, cioè da oltre 13 anni (Fig. 5). Un sistema senza aggiornamenti accumula vulnerabilità che non verranno più corrette: la soluzione è migrare a una versione supportata.

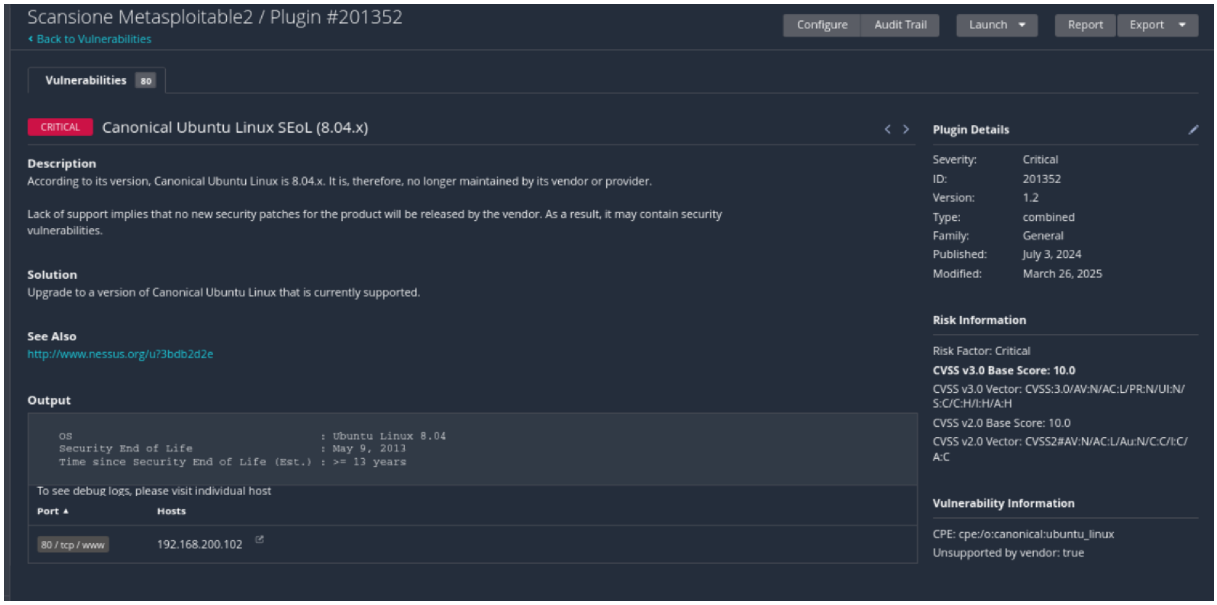


Figura 5: Ubuntu 8.04 fuori supporto dal 9 maggio 2013.

4.3 Altre vulnerabilità rilevate

La Fig. 6 mostra l'elenco delle vulnerabilità dell'host, ordinate per gravità, a partire dalla Bind Shell. Poiché i caratteri dello screenshot sono piccoli, la Tabella 2 ne riporta il

contenuto, escluse le voci legate a Log4j e al modulo NodeJS, discusse nella sezione 4.4. Il punteggio è quello CVSS indicato da Nessus.

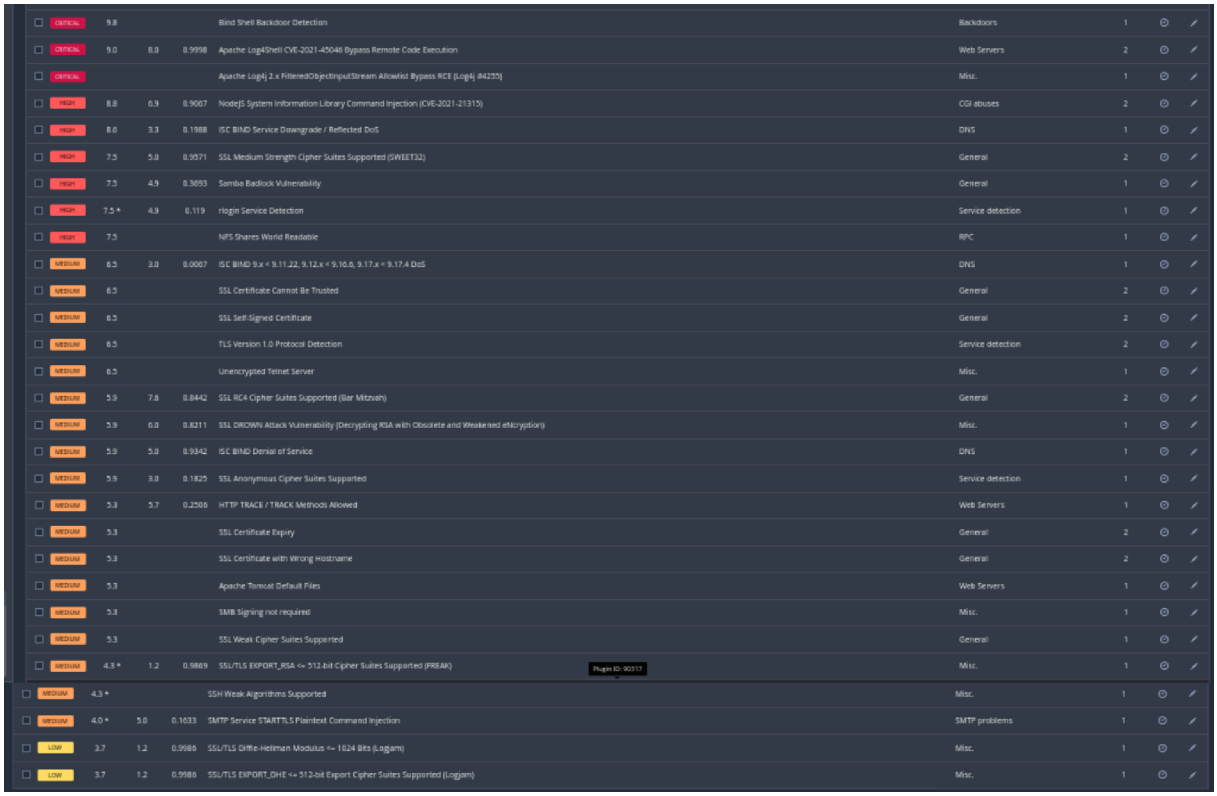


Figura 6: Elenco delle vulnerabilità con gravità critica, alta, media e bassa.

Tabella 2: Vulnerabilità rilevate da Nessus, escluse quelle trattate come probabili falsi positivi.

Gravità	**CVSS**	**Vulnerabilità**	**Famiglia**
Critica	10.0	Canonical Ubuntu Linux SEoL (8.04.x)	General
Critica	9.8	Bind Shell Backdoor Detection	Backdoors
Alta	8.6	ISC BIND Service Downgrade / Reflected DoS	DNS
Alta	7.5	SSL Medium Strength Cipher Suites Supported (SWEET32)	General
Alta	7.5	Samba Badlock Vulnerability	General
Alta	7.5	rlogin Service Detection	Service detection
Alta	7.5	NFS Shares World Readable	RPC
Media	6.5	ISC BIND 9.x < 9.11.22, 9.12.x < 9.16.6, 9.17.x < 9.17.4 DoS	DNS
Media	6.5	SSL Certificate Cannot Be Trusted	General
Media	6.5	SSL Self-Signed Certificate	General
Media	6.5	TLS Version 1.0 Protocol Detection	Service detection
Media	6.5	Unencrypted Telnet Server	Misc.
Media	5.9	SSL RC4 Cipher Suites Supported (Bar Mitzvah)	General

Gravità	CVSS	Vulnerabilità	Famiglia
Media	5.9	SSL DROWN Attack Vulnerability	Misc.
Media	5.9	ISC BIND Denial of Service	DNS
Media	5.9	SSL Anonymous Cipher Suites Supported	Service detection
Media	5.3	HTTP TRACE / TRACK Methods Allowed	Web Servers
Media	5.3	SSL Certificate Expiry	General
Media	5.3	SSL Certificate with Wrong Hostname	General
Media	5.3	Apache Tomcat Default Files	Web Servers
Media	5.3	SMB Signing not required	Misc.
Media	5.3	SSL Weak Cipher Suites Supported	General
Media	4.3	SSL/TLS EXPORT_RSA $\leq$ 512-bit Cipher Suites Supported (FREAK)	Misc.
Media	4.3	SSH Weak Algorithms Supported	Misc.
Media	4.0	SMTP Service STARTTLS Plaintext Command Injection	SMTP problems
Bassa	3.7	SSL/TLS Diffie-Hellman Modulus $\leq$ 1024 Bits (Logjam)	Misc.
Bassa	3.7	SSL/TLS EXPORT_DHE $\leq$ 512-bit Export Cipher Suites Supported (Logjam)	Misc.

Le voci si possono riassumere in quattro gruppi:

- **Servizi di accesso remoto in chiaro:** Telnet e rlogin trasmettono credenziali e comandi senza cifratura, e rlogin può basarsi sulla sola fiducia tra host.
- **Condivisione di file:** le esportazioni NFS sono leggibili da chiunque, Samba è vulnerabile a Badlock e non richiede la firma dei messaggi SMB, che resta esposto ad attacchi di tipo man-in-the-middle.
- **Software non aggiornato:** il server DNS BIND presenta tre vulnerabilità di tipo denial of service, Tomcat espone i file di esempio installati di default e il server web accetta i metodi TRACE e TRACK.
- **Cifratura debole:** certificati autofirmati, scaduti o con nome errato, protocolli superati (SSLv2, TLS 1.0) e cifrari deboli o di esportazione (RC4, SWEET32, FREAK, DROWN, Logjam), oltre ad algoritmi SSH deboli.

4.4 Probabili falsi positivi

Ordinando l'elenco per punteggio, le prime righe sono tutte varianti di un'unica vulnerabilità: *Apache Log4Shell RCE detection*, cioè la CVE-2021-44228 della libreria Java Log4j (Fig. 7). La sola variante *via Raw Socket* compare 25 volte; le varianti *via callback correlation* sono distribuite nelle famiglie RPC, FTP, DNS, SMTP, Web Servers e altre. Insieme alle voci collegate (CVE-2021-45046 e Log4j 2.x FilteredObjectInputStream) arrivano ad almeno 50 delle 64 rilevazioni critiche.

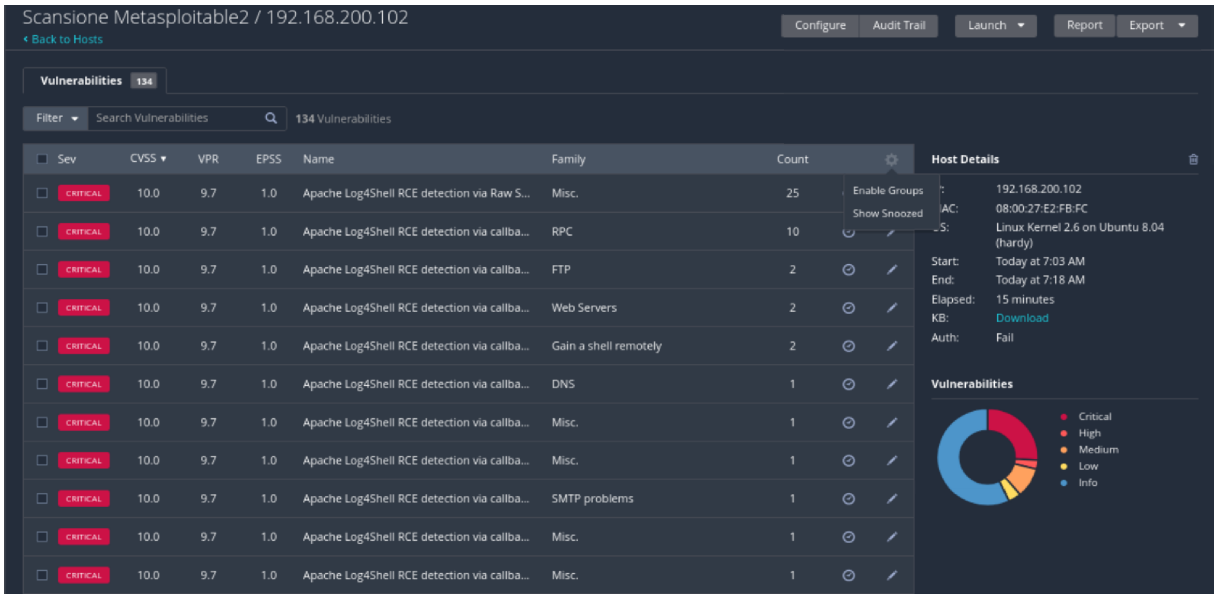


Figura 7: Elenco senza raggruppamento: le prime voci per punteggio sono tutte varianti di Log4Shell.

Diversi elementi indicano che queste segnalazioni non sono attendibili:

- **Il software non è compatibile:** Log4j 2 è una libreria Java, pubblicata nel 2014. Metasploitable2 è basata su Ubuntu 8.04, del 2008, e le porte su cui viene segnalata (DNS, FTP, Telnet, NetBIOS) sono servite da programmi che non usano Java.
- **L'evidenza non è specifica:** per la porta 53 l'output del plugin spiega che Nessus ha inviato una richiesta DNS con un nome di prova e che il bersaglio ha poi cercato quel nome (Fig. 8). Il servizio in ascolto è però il server DNS BIND, il cui compito è proprio risolvere i nomi che riceve: il comportamento osservato è quello normale di un server DNS e non dimostra la presenza di Log4j.
- **I requisiti del controllo non sono soddisfatti:** la descrizione del plugin 156014 precisa che il controllo richiede che sia lo scanner sia il bersaglio abbiano accesso a Internet (Fig. 9), mentre Metasploitable2 si trova in una rete interna isolata.

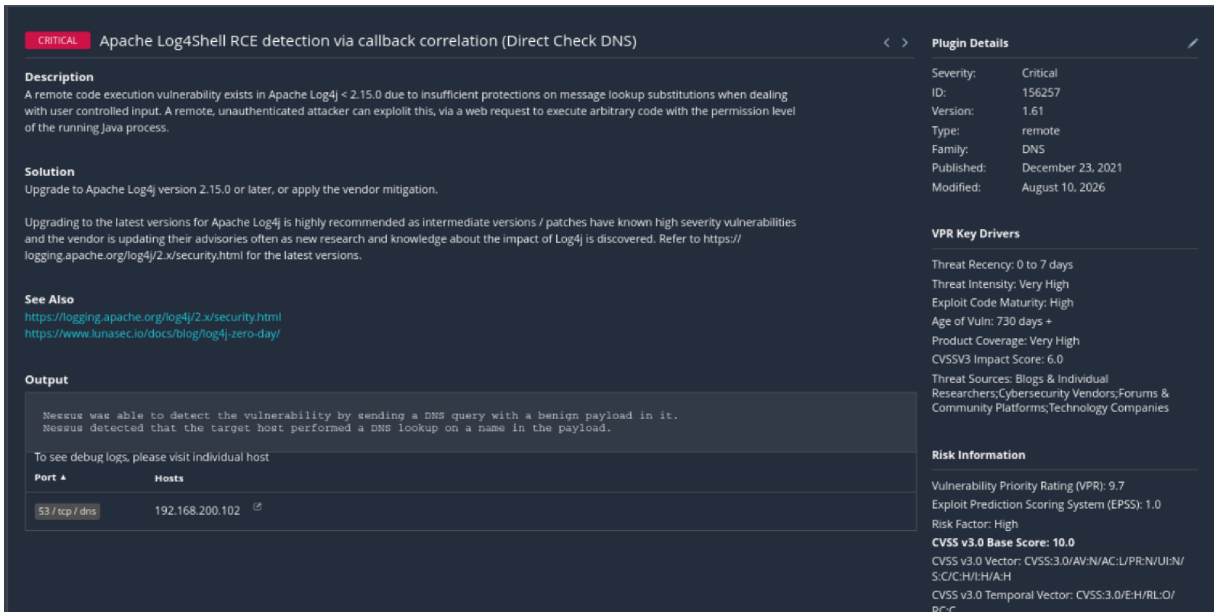


Figura 8: Log4Shell sulla porta 53: l'unica evidenza è una ricerca DNS eseguita dal server DNS.

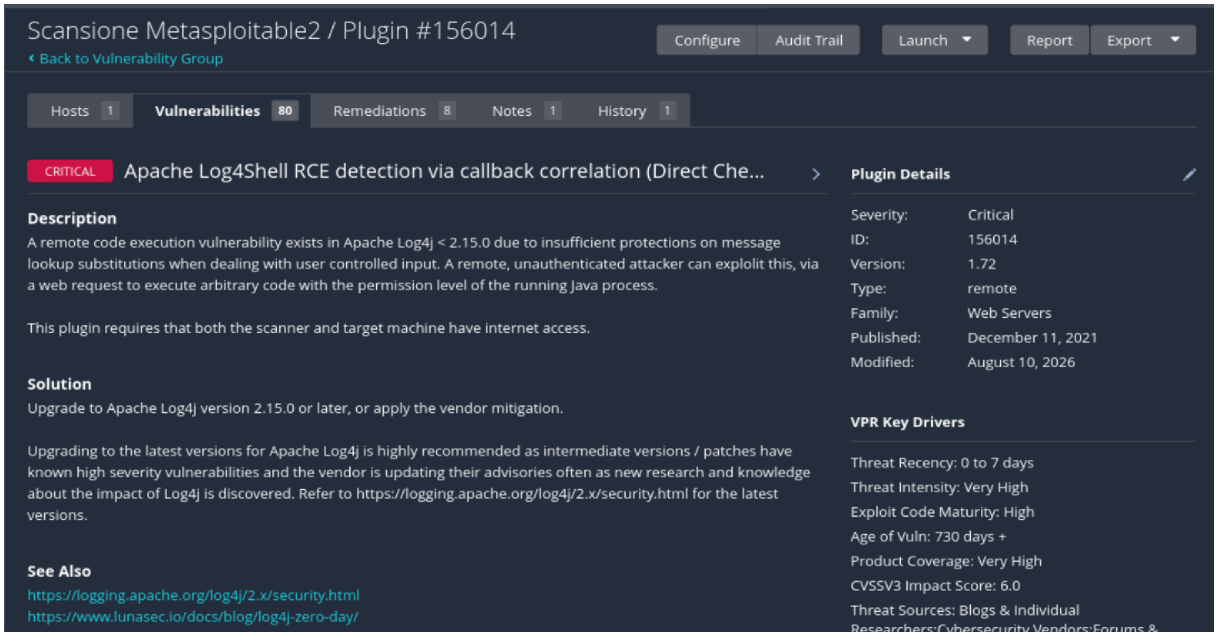


Figura 9: Il plugin 156014 richiede che scanner e bersaglio abbiano accesso a Internet.

Considerazioni simili valgono per altre due voci, che riguardano software di cui non c'è traccia tra i servizi rilevati da Nmap: *NodeJS System Information Library Command Injection* (CVE-2021-21315, gravità alta) e *Oracle E-Business Suite Remote Code Execution* (CVE-2025-61882), che compare nella scheda *Remediations* (Fig. 10). La stessa scheda riassume le 8 azioni correttive proposte da Nessus: quattro riguardano Log4j, le altre l'aggiornamento di BIND e Samba e i due prodotti appena citati.

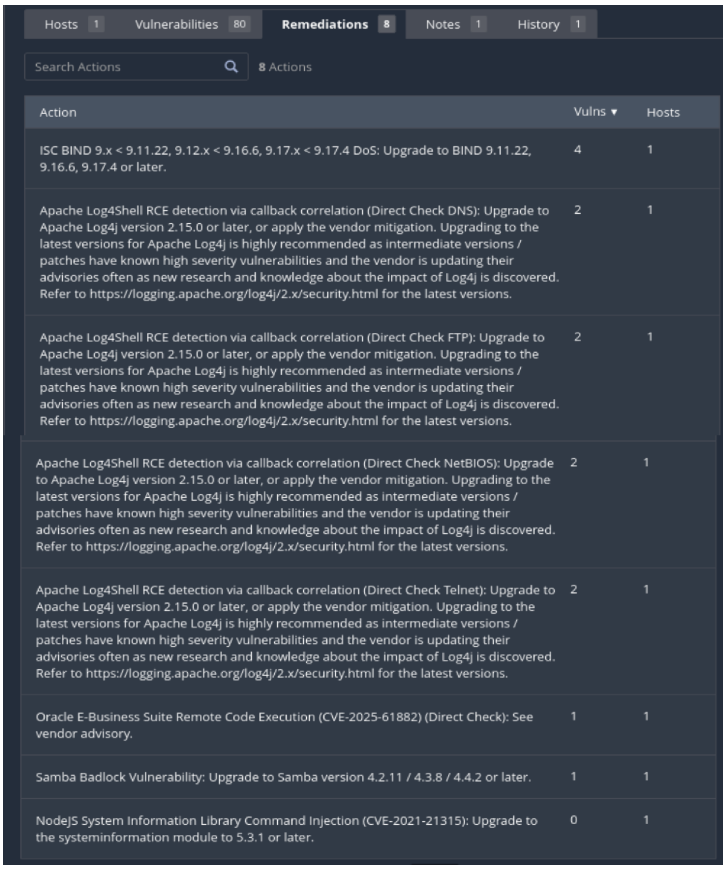


Figura 10: Azioni correttive proposte da Nessus nella scheda Remediations.

Le voci su Log4j riportano anche un VPR di 9.7 e un EPSS di 1.0. Questi indicatori descrivono quanto è pericolosa e sfruttata la vulnerabilità in generale, non se è davvero presente sull'host: un falso positivo eredita quindi i punteggi massimi e finisce in cima alle priorità. Per questo, prima di inserire queste voci in un piano di intervento, andrebbero verificate, ad esempio con una scansione autenticata o controllando i pacchetti installati, e poi declassate con le regole dei plugin di Nessus.

4.5 Confronto con la scansione Nmap

Le vulnerabilità con un nome specifico trovano riscontro nei servizi che Nmap aveva individuato sulla stessa macchina (Tabella 3).

Tabella 3: Servizi rilevati da Nmap e vulnerabilità corrispondenti in Nessus.

Servizio (porta)	**Evidenza in Nmap**	**Risultato in Nessus**
Bindshell (1524)	*Metasploitable root shell*	Bind Shell Backdoor Detection: comando `id` eseguito come root
Telnet (23)	Linux telnetd	Unencrypted Telnet Server
rlogin (513)	Servizio `login`	rlogin Service Detection
NFS (2049)	NFS 2-4 (RPC #100003)	NFS Shares World Readable
Samba (139, 445)	Samba smbd 3.0.20-Debian, firma dei messaggi disabilitata	Samba Badlock Vulnerability, SMB Signing not required

Servizio (porta)	Evidenza in Nmap	Risultato in Nessus
DNS (53)	ISC BIND 9.4.2	Tre vulnerabilità di BIND (denial of service e downgrade)
SMTP (25)	Postfix con SSLv2 supportato e certificato scaduto	STARTTLS Plaintext Command Injection; debolezze SSL/TLS e certificati non validi
SSH (22)	OpenSSH 4.7p1	SSH Weak Algorithms Supported
HTTP (80)	Apache httpd 2.2.8	HTTP TRACE / TRACK Methods Allowed; sistema fuori supporto, rilevato tramite il servizio web
Tomcat (8180)	Apache Tomcat 5.5	Apache Tomcat Default Files

I due strumenti si completano. Nmap ha esaminato tutte le porte TCP e ha descritto con precisione servizi e versioni, ma lascia all'analista il compito di capire quali versioni sono vulnerabili. Nessus, limitato alle porte comuni, associa a ogni servizio vulnerabilità note, punteggi e soluzioni, e in alcuni casi dimostra il problema, come il comando eseguito sulla Bind Shell; in cambio produce anche risultati non attendibili, che vanno riconosciuti e scartati.

4.6 Contromisure

In un ambiente reale le priorità sarebbero queste:

- **Gestire la Bind Shell come un incidente:** isolare la macchina, verificare se è stata compromessa e reinstallarla da un'immagine pulita.
- **Migrare a un sistema supportato:** sostituire Ubuntu 8.04 con una versione che riceve ancora aggiornamenti di sicurezza, così da correggere insieme anche Samba, BIND, OpenSSH e il server web.
- **Disattivare i servizi in chiaro:** eliminare Telnet e rlogin e usare SSH con algoritmi moderni.
- **Limitare le condivisioni:** esportare via NFS solo le cartelle necessarie e solo verso host autorizzati, rendere obbligatoria la firma SMB.
- **Rafforzare la cifratura:** disattivare SSLv2, SSLv3 e TLS 1.0, rimuovere i cifrari deboli e installare certificati validi emessi da un'autorità riconosciuta.
- **Ridurre l'esposizione del web server:** disattivare i metodi TRACE e TRACK e rimuovere i file di esempio di Tomcat.
- **Validare i risultati dello scanner:** ripetere la scansione con credenziali e verificare le voci sospette prima di pianificare gli interventi.

5 Conclusioni

La scansione con Nessus ha confermato e approfondito il quadro emerso con Nmap: Metasploitable2 espone una shell di root senza autenticazione, gira su un sistema fuori supporto da oltre 13 anni e offre numerosi servizi obsoleti, in chiaro o configurati con cifratura debole. Rispetto a Nmap, Nessus collega ogni servizio a vulnerabilità note, con punteggi e soluzioni, e in alcuni casi ne dimostra lo sfruttamento.

L'esercitazione ha mostrato anche il limite principale di uno scanner automatico: la maggior parte delle rilevazioni critiche riguardava Log4Shell su servizi che non possono contenere Log4j. Per un analista SOC il valore del vulnerability assessment non sta nel numero di vulnerabilità prodotto dallo strumento, ma nella capacità di leggere l'output dei plugin, separare le evidenze reali dai falsi positivi e ordinare gli interventi in base al rischio effettivo. Il passo successivo naturale è una scansione autenticata, che permette a Nessus di controllare direttamente i pacchetti installati e riduce i falsi positivi.